# Trade Compliance Monitoring Platform — End-to-End Architecture (Microsoft Foundry multi-agent · EU + US)

200,000 transactions/day · two self-contained regional stacks · 99.9% availability · MiFID II · EMIR · Dodd-Frank · GDPR · EU AI Act (high-risk) · a human compliance officer reviews every flagged case before any report is filed; routine T+1 reports auto-file

ON-PREMISES SYSTEMS & USERS

OUTSIDE THE TRUST BOUNDARY

## EU REGION — DATA RESIDENCY BOUNDARY

Primary: **Sweden Central** (3 availability zones, active) · Standby: **Germany West Central** (warm, in-geography) · Foundry **Data Zone EU** only · failover never leaves the EU · own subscription, VNets, keys and logs

audit events — every workflow step (hash-chained)

L3 output checks (groundedness, harm, PII)

**EU trade capture / OMS / booking**
EU legal entities · ExpressRoute private peering · mTLS · FIX / ISO 20022 → JSON

**Application Gateway WAF v2** (L1)
Private frontend (ExpressRoute) · OWASP DRS 2.1 prevention · bot rules · TLS 1.2+ · zone-redundant

**API Management Premium** (L1 · O1)
Unified AI + MCP gateway (internal VNet)
• validate-jwt (Entra) · mTLS producers
• validate-content (tcm JSON Schema)
• geo-pinning: non-EU entity → HTTP 421
• llm-token-limit · rate-limit-by-key
• llm-content-safety (Prompt Shields)
• llm-emit-token-metric (cost by agent/BU)
• backend pools + circuit breaker
• MCP registry (pinned tool hashes)

**Service Bus Premium** (PE)
Intake queue · session = correlation_id · DLQ · in-geography DR

**PII Tokenization Service**
Names, client IDs, accounts → HMAC-SHA256 tokens before any agent sees data · keys in Managed HSM

**EU compliance officers**
Entra ID · phishing-resistant MFA · reviewer & four-eyes approver roles

**Reviewer portal ingress**
App Gateway WAF listener · Entra ID pre-auth · Conditional Access (phishing-resistant MFA)

**FOUNDRY WORKFLOWS** — Foundry Agent Service (L3 · O2)

**ORCHESTRATOR AGENT**
• Foundry Agent Service hosted agent · own Entra Agent ID
• Assigns correlation_id TCM-EU-{yyyymmdd}-{ULID}
• Tools: **fiq-regulatory** · **fiq-internal-policy** (Foundry IQ) · **mcp-regfeed** · **mcp-sanctions-lists** · **mcp-casemgmt** (MCP)
• Calls 5 specialists as A2A connected agents
• Aggregates typed findings · writes reviewer narrative (grounded, cited)
• Fresh thread per transaction — no cross-trade memory; state in Cosmos DB (EU, TTL)
• Has **no filing tool** — cannot file flagged reports
• Single audit writer (event-sourced)

**Jurisdiction router**
deterministic · EU venue/entity → MiFID II · EU OTC derivative → EMIR · US-person swap → Dodd-Frank

**Escalation policy gate**
versioned rules: risk ≥ 70 · sanctions ≥ 0.85 · STOR signal · INDETERMINATE · agent disagreement

**HITL CHECKPOINT**
workflow pauses until a signed reviewer decision arrives · no auto-approve on timeout

**Routine T+1 path**
unflagged, fully validated reports → reporting gateway (auto-file)

ESCALATE → reviewer package
← **signed decision** resumes workflow

**HUMAN COMPLIANCE OFFICER REVIEW QUEUE** (O7)
Case management system (via mcp-casemgmt) + Service Bus review queue
• Package: findings + citations, score drivers, sanctions match detail, T+1 timer
• Decision: approve-file / reject / escalate-MLRO + reason code, Key Vault-signed
• Four-eyes for STOR & sanctions · SLA 4 business hours · auto-escalate before cut-off

grounding via fiq-* connections

**SPECIALIST AGENTS** — A2A · typed handoff tcm.handoff.v1 · least-privilege fields

① **MiFID II Rule Checking Agent** (O3)
RTS 22 (65 fields) · reportability · RTS 25 time · STOR signals · kb-mifid2-mifir

① **EMIR Rule Checking Agent** (O3)
REFIT T+1 · UTI/UPI · FC/NFC classification · clearing · kb-emir-refit

① **Dodd-Frank Rule Checking Agent** (O3)
CFTC Parts 43/45 · US-person test · SEC SBSR · kb-doddfrank-cftc

① **Sanctions Screening Agent** (O3)
fuzzy-match adjudication vs cached EU/UN/UK/OFAC lists · fail-closed

② **Risk Scoring Agent** (O3)
0–100 score + top-5 drivers via risk-model endpoint · kb-internal-policy

*A2A: correlation_id · typed schema · timeouts 8 s soft / 15 s hard · retry ×3 full jitter · circuit breaker → fallback*

grounded retrieval

tool calls

**FOUNDRY IQ (EU)** (L2 · O4)
knowledge bases · agentic retrieval on Azure AI Search

**kb-mifid2-mifir** — MiFIR RTS 22 · ESMA Q&A

**kb-emir-refit** — EMIR REFIT standards · validation rules

**kb-doddfrank-cftc** — CFTC Parts 43/45 · SEC SBSR

**kb-sanctions-guidance** — EU / OFAC / OFSI guidance

**kb-internal-policy** — firm policy · risk appetite · precedents

fiq-regulatory · fiq-internal-policy · index-scoped RBAC per agent · versioned snapshots (kb_version in every finding) · ingestion passes L2 sanitisation

PE

**MCP CONNECTIONS** (O5)
registered in APIM MCP gateway · Entra-authenticated

**MCP sanitising proxy (Container Apps, internal)** (L2)
**L2 controls:** pinned tool-definition hashes · strict JSON Schema on every response · NFKC + strip hidden text / HTML / URLs · signature & list-delta checks · Prompt Shields (document attacks) · instruction-pattern rejection → quarantine · spotlighting (data, never instructions)

**mcp-casemgmt**
private · OAuth 2.1 (Entra) · create_case · get_decision → review queue

**mcp-regfeed**
read-only · ESMA FIRDS · GLEIF LEI · regulatory change notices

**mcp-sanctions-lists**
pull-only · EU · UN · UK · OFAC snapshots · signed

**Azure AI Content Safety** (L1 · L2 · L3)
Prompt Shields (user-prompt attacks + document attacks) · harm filters block ≥ Medium · groundedness detection · protected material · task adherence · custom blocklists
**Applied at L1** user input (APIM) · **L2** tool responses & Foundry IQ chunks · **L3** agent output before reviewer package / filing

PE

**Foundry Models — Data Zone EU**
Provisioned throughput (PTU) + Data Zone Standard spill-over via APIM backend pool · approved-model list & pinned versions (Azure Policy) · Global SKUs denied

PE

**DATA & AUDIT**
EU-resident · customer-managed keys · private endpoints only

**Audit pipeline: Event Hubs → Immutable Blob (WORM)** (O6)
Hash-chained events: ESCALATION_CREATED · REVIEW_DECISION · filing receipts · model/policy versions · locked 7-year retention (MiFID II) · in-geography replication only · tokens, never identities

PE

**Identity Vault**
token ↔ identity map · PIM-gated re-identification · per-year key crypto-shred

PE

**Cosmos DB**
BYO agent thread & workflow state · TTL 30 days after case close

PE

**Key Vault + HSM**
CMK · tokenisation keys · approval-token signing keys

PE

routine T+1 auto-file (unflagged)

allowlisted HTTPS pull — untrusted content

**Managed Online Endpoints (blue / green)**
Deterministic rules engine (fallback for rule agents) · risk-scoring model (validated) · 3–12 instances across AZs · autoscale on CPU / p95 · traffic split + 10% mirror

PE

**Private networking (hub-spoke)**
ExpressRoute gateway · Private DNS Resolver · private-endpoint subnet + private DNS zones · public network access disabled on every PaaS service · UDRs force egress through the firewall · no VNet peering with the US stack

**Regulatory Reporting Gateway — workflow step, NOT an agent tool** (L3)
• Routine T+1 reports auto-filed after deterministic validation
• Flagged reports, STORs and amendments require a signed reviewer approval token
• ARM → NCA (MiFIR RTS 22) · EMIR trade repository · NCA STOR (MAR Art. 16)
• Submission receipts written back to the audit pipeline (report_ref)

approved → file (signed approval token)

**AZURE FIREWALL PREMIUM — EGRESS · FQDN allowlist · TLS inspection · IDPS · UDR-forced**

**EXTERNAL REGULATORY DATA FEEDS**
untrusted content · ESMA FIRDS & registers · GLEIF LEI · ESMA / NCA / CFTC regulatory change notices

**SANCTIONS LIST PUBLISHERS**
untrusted content · EU Consolidated · UN · UK OFSI · OFAC SDN

**EU REGULATORY DESTINATIONS**
ARM → NCA (MiFIR RTS 22 transaction reports) · EMIR trade repository · NCA STOR (MAR Art. 16) — mTLS, allowlisted

**OBSERVABILITY (EU-resident)** — OpenTelemetry GenAI semantic conventions · correlation_id + W3C traceparent on every span · prompt/completion content capture disabled in production

**Application Insights**
Distributed traces APIM → orchestrator → specialists → Foundry IQ → MCP → audit pipeline · token & cost metrics per agent · live failure analysis

**Azure Monitor**
Metrics · alert rules · action groups (SRE on-call, Compliance Technology, SOC) · workbooks · Foundry Control Plane agent dashboards

**Log Analytics workspace (EU)**
Azure Monitor Private Link Scope · 90-day interactive retention · feeds Sentinel · no personal data

PE

**INSTRUMENTATION POINTS (full chain)**
**O1** APIM gateway — requests, tokens, WAF / Prompt Shields blocks
**O2** orchestrator invoke_agent — end-to-end latency, escalation rate, queue age
**O3** specialist invoke_agent + chat spans — duration, status, retries, fallback used
**O4** Foundry IQ retrieve — latency, reranker score, kb_version, zero-result rate
**O5** MCP execute_tool — status, latency, circuit state, injection verdict, snapshot age
**O6** audit.write — success / failure, consumer lag, hash-chain check · **O7** review queue — SLA, backlog

identities · RBAC | policy assignment (deny / audit / DINE) | signed release (blue/green) | security signals | aggregated non-PII metrics

## GLOBAL CONTROL PLANE

identity · policy · release · security governance

**Residency rule:** no transaction or personal data crosses EU → US through this plane — only policy assignments, signed release artefacts and aggregated non-PII metrics.

**Microsoft Entra ID**
Entra Agent ID per agent · managed identities · PIM just-in-time · Conditional Access · OIDC workload federation for CI/CD (no secrets)

**Azure Policy**
**GDPR-Data-Residency** (allowed locations, deny Global SKUs) · **EU-AI-Act-HighRisk** (required tags, guardrail policy, Art. 12 logging) · **Approved-Model-List** · deny public access & key auth

**CI/CD pipeline**
Build & supply-chain checks → **evaluation gate** → **safety gate** → **conformity gate** → blue/green release · dev → test → prod per geography

**Purview + Compliance Manager**
Data map & classification · EU AI Act Annex IV technical file · DPIA · conformity evidence versioned per release

**Defender for Cloud + Sentinel**
AI threat protection (jailbreak, injection, data leakage) · SOC analytics on WAF, firewall and Prompt Shields events

**Global operations dashboard**
Azure Monitor workbook fed only by aggregated, non-PII metrics (volumes, latency, error and escalation rates)

identities · RBAC | policy assignment (deny / audit / DINE) | signed release (blue/green) | security signals | aggregated non-PII metrics

## US REGION — DATA RESIDENCY BOUNDARY

Primary: **East US 2** (3 availability zones, active) · Standby: **Central US** (warm, in-geography) · Foundry **Data Zone US** only · mirror of the EU control set · no VNet peering or shared DNS with EU

audit events (hash-chained)

**US trade capture / OMS / booking**
US legal entities · ExpressRoute · mTLS

**App Gateway WAF v2** (L1)
private frontend · OWASP DRS

**API Management Premium (US)** (L1 · O1)
Same policy set as EU · geo-pinning: non-US entity → 421 · MCP gateway

**Service Bus + PII Tokenization**
intake queue · HMAC tokens (US HSM)

PE

**US compliance officers**
Entra ID · phishing-resistant MFA · four-eyes

**Reviewer portal ingress**
WAF listener · Entra pre-auth · CA + MFA

**FOUNDRY WORKFLOWS** — Foundry Agent Service (L3 · O2)

**ORCHESTRATOR AGENT (US)**
correlation_id TCM-US-… · same tools: fiq-regulatory · fiq-internal-policy · mcp-regfeed · mcp-sanctions-lists · mcp-casemgmt · 5 A2A specialists · no filing tool

**HITL CHECKPOINT**
paused until signed decision

**Router · escalation gate**
routine T+1 → auto-file

ESCALATE ⇄ signed decision

**HUMAN COMPLIANCE OFFICER REVIEW QUEUE (US)** (O7)
Case management (via mcp-casemgmt) · reviewer package · signed decision · four-eyes for sanctions & suspicious-activity filings · SLA 4 business hours

**SPECIALIST AGENTS** (US instances) (O3)

① **MiFID II Rule Checking Agent**

① **EMIR Rule Checking Agent**

① **Dodd-Frank Rule Checking Agent**

① **Sanctions Screening Agent**

② **Risk Scoring Agent**

**FOUNDRY IQ (US)** (L2 · O4)
kb-doddfrank-cftc · kb-mifid2-mifir · kb-emir-refit · kb-sanctions-guidance · kb-internal-policy (US copies; no EU personal data)

PE

**MCP CONNECTIONS (US)** (L2 · O5)
sanitising proxy (L2) · mcp-regfeed · mcp-sanctions-lists · mcp-casemgmt

**Content Safety (US)** (L1 · L2 · L3)
Prompt Shields · harm filters · groundedness · task adherence

PE

**Foundry Models — Data Zone US**
PTU + Data Zone Standard spill-over · approved models only

PE

**Data & audit (US)** (O6)
Event Hubs → Immutable Blob WORM (7 yr, hash-chained) · Identity Vault · Cosmos DB (TTL) · Key Vault + HSM · CMK · tokens, never identities

PE

routine T+1 auto-file (unflagged)

**Managed Online Endpoints (US)**
rules engine (fallback) · risk model · blue/green · zone-redundant

PE

**Private networking (US hub-spoke)**
ExpressRoute · private endpoints + private DNS · public access disabled · no peering with EU

**Regulatory Reporting Gateway (US) — not an agent tool** (L3)
Routine T+1 auto-file · flagged → signed approval token · CFTC SDR (Parts 43/45) · SEC SBSDR · receipts → audit

approved → file (signed approval token)

**AZURE FIREWALL PREMIUM — EGRESS**

**EXTERNAL FEEDS (US)**
untrusted content · CFTC / SEC notices · OFAC SDN · GLEIF LEI

**US REGULATORY DESTINATIONS**
CFTC swap data repository (Parts 43/45) · SEC SBSDR (Reg SBSR) — mTLS, allowlisted

**OBSERVABILITY (US-resident)** — same OpenTelemetry instrumentation O1–O7 · US Log Analytics workspace

**Application Insights (US)**
distributed traces · token metrics

**Azure Monitor (US)**
alerts · action groups · workbooks

**Log Analytics workspace (US)**
AMPLS private link · feeds Sentinel

PE

**O1** APIM · **O2** orchestrator · **O3** specialists · **O4** Foundry IQ · **O5** MCP · **O6** audit pipeline · **O7** review-queue SLA — identical spans, metrics and alert thresholds to EU

## LEGEND

- Transaction / request flow
- Approved filing (signed approval token)
- Governance / control plane
- A2A orchestration · agent tool calls
- Untrusted external data / egress
- Telemetry (OpenTelemetry → App Insights)
- Escalation to human review ⇄ signed decision
- Guardrail call (Azure AI Content Safety)
- Fallback route (circuit breaker open)
- Routine T+1 auto-file (unflagged)
- Audit events (hash-chained)

PE — Private endpoint (public network access disabled)

O2 — Observability instrumentation point O1–O7

L2 — Adversarial AI defence layer: L1 input · L2 tool invocation (MCP) · L3 output

① parallel fan-out · ② sequential after join · dashed region border = data-residency boundary